

Botium Toys

Internal Cybersecurity Audit — Controls & Compliance Assessment

Project Type: Simulated / Academic Cybersecurity Audit

Framework: NIST Cybersecurity Framework (NIST CSF)

Purpose: Assess security controls and compliance practices, identify gaps, and recommend improvements to reduce organizational risk.

Executive Summary

This simulated internal audit assessed Botium Toys' security controls and compliance practices based on the provided scope, goals, assets, and risk assessment. The assessment identified significant gaps in access control, encryption, intrusion detection, backups, disaster recovery, password management, and asset management. Existing strengths include firewall protection, antivirus, physical security, data integrity and availability controls, privacy procedures, and an EU breach-notification plan.

1. Controls Assessment Checklist

Control	Status	Assessment / Evidence
Least Privilege	NO	Not implemented; all employees may access internally stored data.
Disaster Recovery Plans	NO	No disaster recovery plans are currently in place.
Password Policies	YES	A password policy exists, but its requirements are too weak.
Separation of Duties	NO	Not implemented.
Firewall	YES	Firewall is configured to block traffic using security rules.
Intrusion Detection System (IDS)	NO	No IDS has been installed.
Backups	NO	No backups of critical data are currently maintained.
Antivirus Software	YES	Installed and regularly monitored.
Legacy System Monitoring/Maintenance	YES	Legacy systems are monitored and maintained, but scheduling and procedures need improvement.
Encryption	NO	Customer credit-card information is not encrypted.
Password Management System	NO	No centralized password management system exists.
Locks	YES	Offices, storefront, and warehouse have sufficient locks.
CCTV Surveillance	YES	Up-to-date CCTV surveillance is in place.
Fire Detection/Prevention	YES	Functioning fire detection and prevention systems are in place.

2. Compliance Assessment

PCI DSS — Payment Card Industry Data Security Standard

Best Practice	Status	Assessment / Evidence
Only authorized users access cardholder data	NO	All employees may have access to internally stored data and cardholder information.
Card data is stored/processed/transmitted securely	NO	Important access controls and encryption protections are missing.
Implement encryption for card data	NO	Encryption is not currently used for credit-card information.
Adopt secure password management policies	NO	Password policy is weak and there is no centralized password management system.

GDPR — General Data Protection Regulation

Best Practice	Status	Assessment / Evidence
EU customers' data is kept private/secured	NO	Broad internal access and insufficient data protection create privacy risks.
72-hour breach notification plan	YES	A plan exists to notify EU customers within 72 hours of a breach.
Data is properly classified and inventoried	NO	Asset identification/classification and inventory require improvement.
Privacy policies and procedures are enforced	YES	Privacy policies, procedures, and processes have been developed and enforced.

SOC Type 1 / Type 2 — Control Practices

Best Practice	Status	Assessment / Evidence
User access policies are established	NO	Least privilege and separation of duties are not implemented.
PII/SPII is confidential/private	NO	All employees may have access to sensitive internal data.
Data integrity is maintained	YES	Controls have been integrated to ensure data integrity.
Data is available to authorized users	YES	Availability controls are in place.

3. Key Findings & Recommendations

1. Implement Least Privilege

Restrict employees' access to only the systems and data required for their roles.

2. Encrypt Sensitive and Cardholder Data

Implement encryption for customer and payment information at appropriate storage and transmission points.

3. Implement Separation of Duties

Separate critical responsibilities so that one individual does not have excessive control over sensitive processes.

4. Create Backups and a Disaster Recovery Plan

Back up critical data regularly, test restoration, and document procedures for recovering from major incidents.

5. Deploy an IDS

Implement intrusion detection capabilities to identify suspicious network activity.

6. Strengthen Password Security

Improve password requirements and deploy centralized password management to enforce policy.

7. Improve Asset Inventory and Classification

Maintain an accurate inventory of hardware, software, systems, and sensitive data and classify assets by risk and business impact.

8. Improve Legacy-System Management

Create a regular maintenance schedule and clear intervention procedures for legacy systems.

4. Audit Conclusion

The assessment indicates a relatively high security risk due to gaps in access control, encryption, detection, recovery, password management, and asset management. Botium Toys has several foundational controls in place, particularly firewall protection, antivirus, physical security, data integrity, and availability. Addressing the identified high-priority gaps would strengthen the organization's security posture and support its compliance objectives.

Portfolio Note: This document represents a simulated/academic cybersecurity audit based on the Botium Toys case study. Botium Toys is a fictional company used for educational purposes.